ONE-PAGE BRIEF

Post-quantum cryptography review: bitwarden-sdk @ 25b6c8c3860a

Client: Bitwarden — public repository (passive review) · Source: github.com/bitwarden/sdk-internal, commit `25b6c8c3860a` · Reviewed: 2026-10-28 18:19 UTC · Risk profile: Security software vendor

POST-QUANTUM MATURITY

Level 2 of 4

post-quantum in use outside the critical paths

FINDINGS

0 Critical **0** High **7** Medium **11** Low **11** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Key establishment: 10 + 3 − 8 = 5 → **too late**

Signatures: 5 + 3 − 8 = 0 → **tight**

Next step: Extend post-quantum protection to the critical roles that stay classical, starting with what can be recorded today (wrapped keys, channel key exchange).

WHAT MATTERS MOST

Medium QSI-2026-05805	**rsa 0.10.0-rc.18 is affected by RUSTSEC-2023-0071 (CVE-2023-49092)** What to do: Upgrade to a fixed version (none published yet; see the advisory for mitigations).
Medium QSI-2026-05806	**rustls 0.23.45 is affected by GHSA-c8m5-c952-6cm4 (RUSTSEC-2026-0346)** What to do: Upgrade to a fixed version (0.23.46, 0.24.0-dev.2).
Medium QSI-2026-05789	**TLS without a post-quantum key exchange: rustls with the ring crypto provider** preliminary What to do: Build rustls with the aws-lc-rs provider (rustls::crypto::aws_lc_rs) and the prefer-post-quantum feature, which puts X25519MLKEM768 first.
Medium QSI-2026-05790	**Quantum-vulnerable RSA: key wrapping and data encryption at rest (3 file(s))** preliminary What to do: Wrap keys with ML-KEM or a hybrid KEM (X25519 + ML-KEM-768) and re-wrap the stored keys; data that may already have been copied needs its…

14 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium key wrapping and data encryption at rest	RSA	Wrap keys with ML-KEM or a hybrid KEM (X25519 + ML-KEM-768) and re-wrap the stored keys; data that may…
Medium channel key exchange (TLS, Noise, handshakes)	TLS ECDHE	Move the handshake to a hybrid key exchange (X25519MLKEM768 in TLS 1.3; a hybrid KEM in Noise-based protocols)
Low authentication and identity (certificates, tokens, device attestation)	Ed25519, RSA	Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them
Medium role not determined	Ed25519, RSA, ECDH	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)…

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 13; unlikely to apply to this build: 2 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 11.

Static review of source code and manifests; files analysed: 1625. No requests were sent to the owner's systems.

Full report, content SHA-256: `1e4739b3d4d55d63452098b66dfb2f91cf88d4f8816147acca500b5289e09586`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.